Seguridad en los Sistemas de Información

Resumen desarrollado · Parcial 1

Organizado según el temario unificado proporcionado. Desarrollo por tema y subtema, con los controles de la norma y los vínculos con el capítulo 2 de buenas prácticas.

Fuentes: Auditoría y Control Interno; Seguridad y Controles (capítulos 6–9); Seguridad en los Sistemas de Información, capítulo 2; UNE-EN ISO/IEC 27002:2023 (adopta ISO/IEC 27002:2022).

Criterio de lectura. Las referencias de la edición 2007 y las de 2022 se mantienen diferenciadas. Los controles ISO 7.1–7.14 figuran en capítulo 6 y los ISO 5.31 en capítulo 9 por indicación del profesor, aunque su ubicación temática puede ser distinta.

Índice de estudio

- 1. CONTROL INTERNO Y AUDITORÍA INFORMÁTICA
- 2. CÓDIGO DE BUENAS PRÁCTICAS — MARCO PARA RELACIONAR LOS CAPÍTULOS
- 3. CAPÍTULO 6 — GESTIÓN DE OPERACIONES Y COMUNICACIONES
- 4. CAPÍTULO 7 — SEGURIDAD DE ACCESO Y DEL ENTORNO
- 5. CAPÍTULO 8 — SEGURIDAD ORGANIZACIONAL
- 6. CAPÍTULO 9 — GESTIÓN DE LA CONTINUIDAD DEL NEGOCIO

1. CONTROL INTERNO Y AUDITORÍA INFORMÁTICA

El capítulo diferencia dos funciones estrechamente relacionadas pero no intercambiables. El control interno es parte de la gestión y opera permanentemente; la auditoría evalúa evidencias y comunica hallazgos con objetividad. Los dos contribuyen a la protección de activos y al cumplimiento de los objetivos organizacionales.

1.1. Conceptos fundamentales

Para el parcial conviene diferenciar cuatro expresiones: control interno, control interno informático, auditoría informática y control informático. No son conceptos equivalentes.

1.1.1. Definición de control interno

El control interno es el conjunto de actividades, procedimientos y medidas establecidos por la organización para orientar sus operaciones, evitar desviaciones y favorecer el cumplimiento de sus objetivos. No debe reducirse al control contable: también alcanza los procesos administrativos, operativos y tecnológicos.

1.1.2. Definición de control interno informático

El control interno informático verifica de forma habitual que las actividades de los sistemas de información se desarrollen según las políticas, procedimientos, estándares y exigencias legales. Comprueba la validez de los mecanismos implantados por cada responsable y promueve su mejora.

1.1.3. Definición de auditoría informática

La auditoría informática es el proceso sistemático de obtener y evaluar evidencias para determinar si los sistemas protegen activos, conservan la integridad de los datos y contribuyen eficaz y eficientemente a los fines de la organización. Sus conclusiones se comunican mediante informes y recomendaciones.

1.1.4. Definición de control informático

Un control informático es una medida administrativa, organizativa, física o técnica que contiene o modifica los riesgos asociados con la información y su tratamiento. Puede ser una política, una autorización, una validación automática, una copia de seguridad o un registro de operaciones.

1.1.5. Relación entre riesgos, objetivos y controles

Los objetivos de negocio determinan qué información y procesos necesitan protección. El análisis de riesgos identifica amenazas, vulnerabilidades y posibles impactos; los controles se seleccionan para reducir el riesgo hasta un nivel aceptable, y luego se comprueba su eficacia.

1.2. Diferencias entre control interno y auditoría informática [FUNDAMENTAL]

Diferencia central: el control interno participa en el establecimiento y el funcionamiento cotidiano de medidas; la auditoría realiza una evaluación fundada en evidencia. La separación debe mantenerse incluso si ambas funciones se coordinan.

1.2.1. Finalidad y objetivos

El control interno tiene una función operativa y preventiva: procura que las actividades se realicen correctamente. La auditoría tiene una función de evaluación: examina si los controles, procedimientos y resultados son adecuados, eficaces y confiables.

1.2.2. Alcance y responsabilidades

El control interno acompaña los procesos y ayuda a implementar normas y mecanismos de seguimiento. La auditoría examina distintas áreas, obtiene evidencias, emite juicios profesionales y recomienda mejoras; no sustituye a quienes operan los controles.

1.2.3. Actividades permanentes y evaluaciones periódicas

El control interno actúa diariamente como parte de la gestión; la auditoría se desarrolla mediante revisiones planificadas o específicas en momentos determinados. Una revisión continua automatizada puede asistir a la auditoría, pero no elimina la diferencia de responsabilidades.

1.2.4. Implantación y operación de controles frente a revisión independiente

El responsable de un proceso debe diseñar, ejecutar y supervisar sus controles. El auditor valora tanto el diseño como su funcionamiento efectivo, con independencia suficiente para no evaluar como tercero una tarea que él mismo administra.

1.2.5. Dependencia organizacional y destinatarios de los informes

Según el material, el control interno informático suele estar próximo a la dirección informática y reportar su funcionamiento. La auditoría informática informa a la dirección general u órgano de supervisión correspondiente, conservando independencia respecto de los sectores auditados.

1.2.6. Puntos en común y complementariedad

Ambos trabajan sobre riesgos, políticas y controles y buscan preservar los activos y mejorar la confiabilidad de los sistemas. Se complementan: el control interno procura evitar problemas y la auditoría detecta deficiencias y verifica la fortaleza del esquema de control.

Comparación de repaso: control interno y auditoría

Criterio	Control interno	Auditoría informática
Propósito	Prevenir y controlar operaciones	Evaluar riesgos y controles
Temporalidad	Actividad permanente	Revisiones en momentos determinados
Responsabilidad	Gestión y funcionamiento de controles	Obtención de evidencia y opinión independiente
Resultado	Medidas y supervisión cotidiana	Hallazgos, informes y recomendaciones
Destinatarios	Responsables operativos y dirección informática	Dirección y órganos de supervisión

1.3. Control interno informático

Su campo incluye procedimientos diarios, redes, cambios, desarrollo, explotación y seguridad de los recursos informáticos.

1.3.1. Funciones y objetivos

Entre sus objetivos figuran asegurar el cumplimiento de procedimientos, asesorar en la interpretación de normas y verificar que existen mecanismos de control adecuados. También supervisa áreas como producción, desarrollo, bases de datos, redes y microinformática.

1.3.2. Cumplimiento de políticas, normas y procedimientos

Comprueba la observancia de políticas institucionales, estándares de operación y requisitos legales. La existencia de una norma escrita no alcanza: deben asignarse responsables, aplicarse controles y registrar las excepciones para corregirlas.

1.3.3. Prevención de errores, irregularidades y usos indebidos

Los controles buscan disminuir errores, fraude, modificaciones no autorizadas, pérdida de datos y uso indebido de recursos. La segregación de funciones y las autorizaciones formales son ejemplos que reducen oportunidades de abuso.

1.3.4. Responsabilidades sobre los sistemas y recursos informáticos

La seguridad de cada recurso sigue siendo responsabilidad de su propietario o administrador. El área de control interno asesora y verifica, pero no concentra exclusivamente la obligación de ejecutar todos los mecanismos de protección.

1.3.5. Seguimiento del desempeño y de los mecanismos de control

El seguimiento puede analizar incidentes, incumplimientos, cambios, resultados de pruebas y registros de operación. Debe producir información que permita ajustar los controles y comprobar que las medidas siguen siendo adecuadas.

1.4. Auditoría informática

La auditoría utiliza procedimientos de revisión y técnicas de obtención de evidencia para valorar controles y formular recomendaciones.

1.4.1. Funciones y objetivos

La auditoría revisa los controles de los sistemas, la fiabilidad de la información y el desempeño de los recursos informáticos. Puede intervenir en evaluaciones de proyectos, cambios relevantes y operación de aplicaciones, sin asumir su gestión cotidiana.

1.4.2. Obtención y evaluación de evidencias

La evidencia es la base de las conclusiones: políticas, configuraciones, logs, documentación, entrevistas, observaciones y resultados de pruebas. Debe ser suficiente y pertinente respecto del objetivo de la revisión.

1.4.3. Revisión de la eficacia, eficiencia, seguridad y fiabilidad

La eficacia pregunta si el control cumple lo previsto; la eficiencia, si lo hace con uso adecuado de recursos. La fiabilidad examina consistencia de resultados y la seguridad considera protección frente a fallas y amenazas.

1.4.4. Evaluación del diseño y funcionamiento de los controles

Se diferencia el diseño del control —si sería apto para mitigar un riesgo— de su funcionamiento efectivo —si realmente se cumple en las operaciones—. Por ejemplo, puede existir una política de autorizaciones sin evidencia de revisión de permisos.

1.4.5. Comunicación de resultados y recomendaciones

La auditoría presenta hallazgos, consecuencias, evidencias y recomendaciones a los responsables que correspondan. El seguimiento de acciones correctivas permite verificar si se corrigieron las debilidades detectadas.

1.4.6. Auditoría interna y auditoría externa

La auditoría interna pertenece a la estructura de la organización y sirve a su gobierno y dirección. La externa es realizada por profesionales u organizaciones ajenos a ella; ambos tipos deben preservar objetividad respecto de lo revisado.

1.5. Sistema de controles informáticos

Los controles se distinguen por su finalidad y por el ámbito donde se aplican; estas clasificaciones se superponen y no son categorías excluyentes.

1.5.1. Objetivos de control y métodos de control

Los objetivos de control expresan el resultado de seguridad que se pretende conseguir; los métodos de control describen las medidas para alcanzarlo. La elección debe ajustarse al riesgo, la naturaleza del proceso y los recursos disponibles.

1.5.2. Controles preventivos

Los controles preventivos buscan evitar que suceda el evento no deseado, como permisos restringidos, formación, separación de tareas o aprobación previa de cambios.

1.5.3. Controles detectivos

Los detectivos identifican hechos que ya ocurrieron o están ocurriendo, como alertas por accesos anómalos, conciliaciones, revisión de logs y monitoreo de fallos.

1.5.4. Controles correctivos

Los correctivos reducen consecuencias y restablecen condiciones apropiadas, como recuperación de un respaldo, revocación de una cuenta comprometida y corrección de una configuración.

1.5.5. Controles generales y controles de aplicación

Los controles generales cubren la infraestructura y el entorno transversal de TI: acceso, cambios, operación, respaldos y organización. Los de aplicación actúan dentro de un sistema concreto, por ejemplo validación de datos de entrada, procesamiento y resultados.

1.5.6. Áreas de aplicación: organización, desarrollo, explotación y comunicaciones

El sistema de controles alcanza gobierno y estructura del área informática, construcción y modificación del software, explotación diaria de servicios y transmisión de información en redes.

1.5.7. Control de cambios y separación de funciones

Todo cambio relevante debe documentarse, analizar riesgos, aprobarse, probarse y registrarse. Separar desarrollo, aprobación y producción evita que una persona introduzca cambios sin supervisión.

1.6. Relación con las buenas prácticas y la norma

La norma actual incorpora controles relacionados con política, cumplimiento, revisión independiente y protección durante las pruebas de auditoría.

1.6.1. Política y cumplimiento de controles (ISO 27002:2022, 5.1 y 5.36)

ISO 27002:2022 5.1 trata la definición y revisión de políticas; 5.36 aborda la comprobación del cumplimiento de políticas, reglas y normas. La primera fija criterios; la segunda verifica su observancia.

1.6.2. Revisión independiente de la seguridad (ISO 27002:2022, 5.35)

ISO 27002:2022 5.35 recomienda revisiones independientes, planificadas y también ante cambios relevantes, sobre el enfoque organizativo de seguridad y su implantación. La independencia refuerza la objetividad de la evaluación.

1.6.3. Protección de sistemas durante pruebas de auditoría (ISO 27002:2022, 8.34)

ISO 27002:2022 8.34 procura que las actividades de prueba de auditoría no afecten indebidamente a los sistemas operativos: acordar alcance y fechas, controlar herramientas y accesos, y proteger los datos utilizados.

2. CÓDIGO DE BUENAS PRÁCTICAS — MARCO PARA RELACIONAR LOS CAPÍTULOS

Este capítulo funciona como mapa de correspondencias. Se estudia el código de buenas prácticas presentado en el capítulo 2 de la cátedra, referido a ISO 27002:2007, y se relacionan sus categorías con los capítulos posteriores y con la estructura reorganizada de ISO 27002:2022.

2.1. Norma ISO/IEC 27002 como código de buenas prácticas

El capítulo 2 explica la lógica de los objetivos y categorías de controles de la edición 2007; la edición 2022 conserva el propósito de orientar controles, pero organiza el contenido de otra manera.

2.1.1. Finalidad y alcance

ISO/IEC 27002 es una guía de referencia para seleccionar e implementar controles de seguridad de la información. Su función es orientar buenas prácticas; no debe confundirse con los requisitos de un sistema de gestión definidos en ISO/IEC 27001.

2.1.2. Relación con la gestión de la seguridad de la información

La norma se vincula con la gestión de riesgos y con el sistema de gestión de seguridad de la información (SGSI). La organización selecciona controles atendiendo a sus objetivos, obligaciones, riesgos y contexto, en lugar de aplicar indiscriminadamente todos los controles.

2.1.3. Estructura de la versión 2007 utilizada en el capítulo 2

El capítulo 2 de la cátedra describe ISO/IEC 27002:2007: apartados introductorios y once secciones temáticas de controles, desde políticas hasta cumplimiento. Esa clasificación es útil para agrupar problemas de seguridad en un marco común.

2.1.4. Objetivos de control, controles y directrices de implementación

Cada categoría tiene objetivos de control y controles específicos acompañados de orientaciones para implementarlos e información adicional. El objetivo indica qué se busca proteger; las directrices ayudan a traducirlo en medidas concretas.

2.1.5. Estructura de controles de la versión 2022: organizativos, de personas, físicos y tecnológicos

La edición ISO/IEC 27002:2022 reorganiza los controles en cuatro grupos: organizativos (capítulo 5), de personas (6), físicos (7) y tecnológicos (8). Los números cambiaron, por lo que una referencia antigua no debe equipararse automáticamente con una actual.

2.1.6. Correspondencia conceptual entre las ediciones 2007 y 2022

La correspondencia entre versiones es conceptual, no numérica. Por ejemplo, gestión de operaciones (sección 10 de 2007) hoy distribuye medidas entre controles organizativos, físicos y tecnológicos; para comparar se debe estudiar la función y no solo el código.

2.2. Análisis, evaluación y tratamiento de riesgos (sección 4 de 2007)

El análisis de riesgos identifica información y activos de valor, amenazas, vulnerabilidades, probabilidad e impacto. El tratamiento decide si se aplican controles, se evita o transfiere un riesgo, o se acepta el residual conforme a criterios de la organización.

2.3. Política de seguridad de la información (sección 5 de 2007)

La política de seguridad expresa el compromiso y la orientación de la dirección, fija criterios y responsabilidades y debe comunicarse. Es necesario revisarla ante cambios organizacionales, tecnológicos o de requisitos aplicables.

2.4. Organización de la seguridad de la información (sección 6 de 2007) → Capítulo 8

En la edición 2007, la sección 6 agrupa infraestructura de seguridad y relaciones con terceros. Se relaciona con la coordinación de la seguridad, responsables, acuerdos y proveedores del capítulo 8 de la cátedra.

2.5. Gestión de activos (sección 7 de 2007) → Capítulo 8

La sección 7 de 2007 se refiere al inventario, responsabilidad por activos y clasificación de la información. Estos aspectos se desarrollan en la gestión organizacional de activos y respaldan decisiones sobre acceso, respaldo y continuidad.

2.6. Seguridad de recursos humanos (sección 8 de 2007) → Capítulos 7 y 8

La sección 8 de 2007 sigue el ciclo laboral: antes, durante y al finalizar o cambiar la contratación. Sus contenidos reaparecen en los capítulos 7 y 8, y se complementan con los controles de personas 6.1 a 6.8 de 2022.

2.7. Seguridad física y del entorno (sección 9 de 2007) → Capítulo 7

La sección 9 de 2007 trata áreas seguras y equipamiento. Se corresponde en contenido con control de acceso físico, protección ambiental e instalaciones, y con los controles físicos 7.1 a 7.14 de la edición 2022.

2.8. Gestión de operaciones y comunicaciones (sección 10 de 2007) → Capítulo 6

La sección 10 de 2007 reúne operación, servicios externos, capacidades, malware, copias, redes, soportes, intercambios y monitoreo. Estos contenidos constituyen el núcleo del capítulo 6 de la cátedra.

2.9. Control de acceso (sección 11 de 2007) → Capítulo 7

La sección 11 de 2007 aborda política de acceso, administración de cuentas, responsabilidades de usuarios y restricciones de acceso a sistemas. En 2022 el eje organizativo más directo está en 5.15 a 5.18.

2.10. Adquisición, desarrollo y mantenimiento de sistemas (sección 12 de 2007) → Capítulos 6 y 8

La sección 12 de 2007 incorpora seguridad en la adquisición, desarrollo y mantenimiento del software. Su aplicación práctica requiere requisitos de seguridad, gestión de cambios, pruebas y separación de ambientes.

2.11. Gestión de incidentes de seguridad (sección 13 de 2007) → Capítulos 6, 8 y 9

La sección 13 de 2007 organiza la notificación, gestión y aprendizaje de los incidentes. Es transversal a operación, responsabilidades organizacionales y recuperación del negocio.

2.12. Gestión de la continuidad del negocio (sección 14 de 2007) → Capítulo 9

La sección 14 de 2007 vincula seguridad y continuidad del negocio. Se relaciona con la identificación de procesos críticos, el análisis de impactos y los planes que permiten mantener o restaurar servicios.

2.13. Cumplimiento (sección 15 de 2007) → Control interno, auditoría y capítulos 6 a 9

La sección 15 de 2007 se refiere al cumplimiento legal, reglamentario, contractual y de las propias reglas de seguridad. También sostiene la revisión de controles que realizan control interno y auditoría.

3. CAPÍTULO 6 — GESTIÓN DE OPERACIONES Y COMUNICACIONES

La operación segura requiere procedimientos documentados, responsabilidades y monitoreo. Los contenidos de los controles físicos 7.1 a 7.14 se añaden tal como pidió la cátedra, aunque por temática también guardan relación con el capítulo de acceso y entorno.

3.1. Objetivos de la gestión de operaciones y comunicaciones

La gestión de operaciones y comunicaciones busca asegurar que los recursos de procesamiento y los medios de comunicación funcionen conforme a requisitos de seguridad. Integra trabajo cotidiano, protección ante malware, respaldos, redes, intercambio de información y vigilancia de las actividades.

3.2. Procedimientos y responsabilidades operacionales

La correcta operación no depende solo de hardware y software; exige documentar qué se hace, quién lo autoriza y cómo se prueba.

3.2.1. Documentación de procedimientos operativos

Los procedimientos operacionales deben documentar tareas normales y excepcionales: arranque y cierre, mantenimiento, resolución de errores, soporte, respaldo y recuperación. La documentación debe mantenerse accesible para personal autorizado y actualizarse ante cambios aprobados.

3.2.2. Responsabilidades de operación y soporte

Cada tarea operativa precisa roles, responsables, mecanismos de escalamiento y autorización. Los acuerdos de soporte y niveles de servicio permiten establecer qué debe hacer el personal interno o un proveedor.

3.2.3. Segregación de funciones y responsabilidades

La segregación impide concentrar en una misma persona la autorización, ejecución y verificación de actividades críticas. Reduce oportunidades de modificaciones no autorizadas y facilita detectar errores o abuso.

3.2.4. Gestión de cambios operativos

Los cambios en sistemas, aplicaciones, configuraciones y procesos deben solicitarse, evaluarse, aprobarse, probarse, documentarse y comunicarse; también deben existir procedimientos para revertirlos si fallan.

3.2.5. Separación de entornos de desarrollo, prueba y producción

Desarrollo, pruebas y producción deben separarse para evitar que ensayos o modificaciones interfieran con datos y servicios reales. El paso a producción exige una aprobación formal y pruebas de aceptación.

3.2.6. Gestión de capacidad y planificación de recursos

La planificación estima necesidades futuras de procesamiento, almacenamiento y comunicación, considerando crecimiento y tendencias. Permite ajustar capacidades antes de que la falta de recursos degrade los servicios.

3.2.7. Aceptación, homologación y pruebas de sistemas

La aceptación de sistemas verifica condiciones acordadas como rendimiento, procesamiento, recuperabilidad, planes de contingencia y medidas de seguridad. Los criterios deben definirse y probarse antes de poner un sistema en uso.

3.2.8. Gestión y supervisión de servicios tercerizados

Los servicios contratados no eximen a la organización de sus obligaciones de seguridad. Deben fijarse condiciones de prestación, responsabilidades, supervisión, revisión de cumplimiento y gestión de cambios del proveedor.

3.3. Protección contra software malicioso

La defensa contra malware requiere medidas organizativas, técnicas y capacitación, no solamente antivirus.

3.3.1. Tipos de software malicioso

El material cita virus, troyanos y bombas lógicas como ejemplos de código malicioso. Son programas o componentes capaces de provocar operaciones no deseadas, perjudicar recursos o comprometer información.

3.3.2. Prevención, detección y recuperación

La protección combina educación, restricción de accesos, programas de detección, análisis de archivos, medidas de recuperación y control de cambios. La detección por sí sola no reemplaza la prevención ni el restablecimiento seguro.

3.3.3. Uso autorizado y licenciamiento del software

Se debe impedir la instalación de aplicaciones no autorizadas y controlar las licencias y procedencia del software. Los archivos descargados, adjuntos y medios externos requieren precauciones antes de ejecutarse.

3.3.4. Análisis y actualización de herramientas de protección

La protección requiere herramientas correctamente instaladas, actualizadas y sometidas a seguimiento. Deben revisarse tanto servidores como estaciones de trabajo y los canales por los que ingresan archivos.

3.4. Copias de seguridad

La política y los procedimientos de respaldo forman un único sistema de protección; lo decisivo es la restauración comprobable.

3.4.1. Objetivos y requisitos de recuperación

Los respaldos procuran que los datos y sistemas esenciales puedan recuperarse después de una pérdida o interrupción. Su valor real depende de que la restauración sea posible en tiempos compatibles con la necesidad del negocio.

3.4.2. Política de copias de seguridad

La política establece qué se copia, quién es responsable, con qué frecuencia, cuánto tiempo se conserva y cómo se resguarda y prueba. Debe corresponder a la criticidad de cada activo.

3.4.3. Copias completas e incrementales

Una copia completa reproduce el conjunto de datos seleccionado; una incremental incluye cambios desde el respaldo anterior relevante. La elección modifica el consumo de almacenamiento y la secuencia necesaria para restaurar.

3.4.4. Frecuencia y criticidad de la información

La frecuencia depende del valor de la información y de la pérdida tolerable. Los datos críticos suelen requerir copias más frecuentes y pruebas de recuperación priorizadas.

3.4.5. Almacenamiento, protección y ubicación remota

Las copias deben protegerse frente a acceso no autorizado, deterioro y desastres que puedan afectar a los originales. El apunte recomienda ubicaciones alejadas y protección física y ambiental apropiada.

3.4.6. Verificación y pruebas de restauración

Hay que verificar la integridad de los medios y ejecutar restauraciones de prueba con regularidad. La existencia de un archivo de copia no demuestra, por sí sola, que el servicio pueda recuperarse correctamente.

3.5. Tratamiento de medios y documentos

Los soportes y documentos requieren protección durante todo su ciclo de vida.

3.5.1. Clasificación y protección de la información almacenada

La clasificación de información determina la protección necesaria durante procesamiento, almacenamiento y traslado. Los soportes y documentos deben resguardarse frente a divulgación, alteración, destrucción o pérdida.

3.5.2. Gestión de soportes removibles

Los medios removibles requieren reglas de autorización, inventario, almacenamiento, manipulación y salida de instalaciones. Su facilidad de traslado aumenta riesgos de extravío o copia indebida.

3.5.3. Transporte seguro de medios

Para transportar medios deben determinarse responsables, embalajes, destinatarios y formas de entrega. El transporte físico forma parte de la seguridad de la transferencia de información.

3.5.4. Eliminación segura de soportes y documentos

Cuando un soporte o documento deja de ser necesario debe eliminarse o destruirse mediante procedimientos seguros, acordes con su clasificación. La simple eliminación lógica puede no impedir su recuperación.

3.6. Gestión de la seguridad de las redes

La red es un activo de comunicación y una vía de exposición de otros activos; su gestión debe responder a la política de seguridad.

3.6.1. Responsabilidades de administración de redes

La gestión de red debe contar con responsabilidades diferenciadas, reglas operativas y supervisión. Esto comprende equipos, conexiones, acceso remoto y servicios propios o contratados.

3.6.2. Protección de infraestructura y tráfico

El objetivo es preservar confidencialidad e integridad de datos en tránsito y disponibilidad de enlaces y recursos. Las medidas combinan configuración segura, controles de comunicaciones y protección de infraestructura.

3.6.3. Servicios de red y niveles de servicio

Deben identificarse servicios de red, garantías de seguridad y niveles de servicio necesarios, e incorporarlos a acuerdos internos o con proveedores. El funcionamiento se supervisa respecto de lo pactado.

3.6.4. Acceso remoto y comunicaciones inalámbricas

El acceso remoto y las redes inalámbricas requieren condiciones explícitas de uso, autenticación y control. Deben gestionarse los equipos remotos y limitar las conexiones a necesidades autorizadas.

3.6.5. Segmentación y controles de red

La segmentación separa redes o zonas de distinta sensibilidad para restringir comunicaciones y limitar propagación de incidentes. Los controles perimetrales y de tráfico apoyan esa separación.

3.7. Transferencia de información y software

Las comunicaciones internas y externas se protegen con reglas formales y responsabilidades explícitas.

3.7.1. Políticas y acuerdos de intercambio

Las transferencias de información y software, internas o con terceros, requieren políticas o acuerdos que definan condiciones, protección y obligaciones. Deben contemplar las exigencias legales, regulatorias y contractuales.

3.7.2. Comunicaciones internas y con terceros

La comunicación entre áreas y organizaciones debe establecer destinatarios, canales autorizados y medidas apropiadas según la clasificación de la información. La responsabilidad se mantiene durante todo el intercambio.

3.7.3. Correo electrónico, servicios web y transferencia de archivos

Correo electrónico, servicios web, descargas y transferencias de archivos son canales frecuentes que necesitan reglas de uso. El material menciona precauciones con reenvíos, adjuntos y canales inalámbricos.

3.7.4. Seguridad y responsabilidades durante la transferencia

Deben asignarse deberes de remitentes, receptores y terceros, y prever el tratamiento de incidentes durante el intercambio. La protección busca evitar interceptación, pérdida, modificación o entrega incorrecta.

3.8. Monitoreo de operaciones y comunicaciones

Monitorear supone generar, proteger, revisar y utilizar registros para tomar decisiones.

3.8.1. Registro de operaciones

Los registros de operaciones pueden reflejar actividad de operadores, inicio y cierre de servicios, errores y acciones correctivas. Son herramientas para rastrear lo ocurrido en los sistemas.

3.8.2. Registro y tratamiento de fallas

Los logs de fallas deben describir el error y las medidas adoptadas; las fallas relevantes requieren reporte, análisis y respuesta, no solo almacenamiento de mensajes.

3.8.3. Registros de auditoría y actividad de usuarios

Los logs de auditoría permiten revisar accesos, actividades de usuarios, modificaciones de configuración y hechos de seguridad. Deben conservar información suficiente para reconstruir sucesos importantes.

3.8.4. Protección, revisión y conservación de logs

Los registros necesitan protección frente a consulta, modificación o eliminación indebida y deben retenerse durante períodos adecuados. Su consulta debe respetar las obligaciones legales aplicables.

3.8.5. Detección y seguimiento de actividades no autorizadas

El seguimiento sistemático de actividades ayuda a descubrir anomalías y posibles usos indebidos. Deben definirse criterios de alerta, responsables de revisión y acciones ante los eventos encontrados.

3.9. Complemento obligatorio: controles físicos ISO 27002:2022, 7.1 a 7.14

Los catorce controles corresponden al capítulo 7 de la edición ISO 27002:2022. Se incluyen en este capítulo exclusivamente por la indicación del docente.

3.9.1. 7.1 Perímetro de seguridad física

ISO 7.1 exige delimitar perímetros para proteger zonas que contienen información y activos críticos. El perímetro puede combinar barreras, puertas y zonas de acceso controlado según el riesgo.

3.9.2. 7.2 Controles físicos de entrada

ISO 7.2 establece controles de entrada para permitir el acceso físico únicamente a personas autorizadas. Se aplican identificación, autorización y registro apropiados a cada área.

3.9.3. 7.3 Seguridad de oficinas, despachos y recursos

ISO 7.3 promueve protección física para oficinas, salas, despachos e instalaciones donde se procesan datos. Considera características del recinto y los activos alojados.

3.9.4. 7.4 Monitorización de la seguridad física

ISO 7.4 prevé vigilancia física para detectar acceso no autorizado o actividades sospechosas mediante observación, alarmas y otros recursos apropiados.

3.9.5. 7.5 Protección contra amenazas externas y ambientales

ISO 7.5 trata eventos externos y ambientales como fuego, inundaciones y otras amenazas naturales o accidentales. Se seleccionan medidas preventivas y de respuesta según los peligros del lugar.

3.9.6. 7.6 Trabajo en áreas seguras

ISO 7.6 define condiciones para trabajar dentro de áreas seguras, incluida la autorización del personal, la supervisión y la protección de las actividades allí realizadas.

3.9.7. 7.7 Puesto de trabajo despejado y pantalla limpia

ISO 7.7 procura evitar exposición de papeles, pantallas y dispositivos desatendidos. Las reglas de escritorio despejado y pantalla limpia reducen divulgaciones accidentales.

3.9.8. 7.8 Emplazamiento y protección de equipos

ISO 7.8 trata la ubicación y protección de equipos frente a accesos indebidos, daños, interferencias y condiciones ambientales adversas.

3.9.9. 7.9 Seguridad de equipos fuera de las instalaciones

ISO 7.9 mantiene medidas de seguridad para dispositivos usados o almacenados fuera de las instalaciones. Los riesgos de transporte, robo o utilización en entornos externos deben considerarse.

3.9.10. 7.10 Soportes de almacenamiento

ISO 7.10 contempla la administración de soportes de almacenamiento durante adquisición, uso, traslado y descarte, con protección acorde a la clasificación de su información.

3.9.11. 7.11 Instalaciones de suministro

ISO 7.11 requiere proteger los servicios de suministro —por ejemplo energía y condiciones auxiliares— de interrupciones que comprometan equipos o información.

3.9.12. 7.12 Seguridad del cableado

ISO 7.12 busca resguardar cableado de energía y comunicaciones contra interferencias, cortes, interceptaciones y daños físicos.

3.9.13. 7.13 Mantenimiento de equipos

ISO 7.13 dispone el mantenimiento correcto de equipos para sostener disponibilidad, integridad y confidencialidad, controlando intervenciones y personal autorizado.

3.9.14. 7.14 Eliminación o reutilización segura de equipos

ISO 7.14 establece que, antes de reutilizar, vender o desechar equipos, se retire o destruya de forma segura la información y los componentes sujetos a protección.

Correspondencia con el capítulo 2 (edición 2007): sección 9, seguridad física y del entorno; los soportes también se relacionan con la sección 10.7.

4. CAPÍTULO 7 — SEGURIDAD DE ACCESO Y DEL ENTORNO

Se distinguen los controles de acceso lógico de los físicos. Ambos responden a una política que tiene en cuenta necesidades del negocio, clasificación de información, autorización y revocación de permisos.

4.1. Política de control de acceso

La política determina la base para decidir accesos según el valor de la información y las funciones de los usuarios.

4.1.1. Objetivos y requisitos del negocio

La política de acceso define quién puede acceder a cada recurso, bajo qué condiciones y según qué necesidades operativas. Debe vincularse a riesgos, funciones del personal y requisitos del negocio.

4.1.2. Clasificación y sensibilidad de la información

La sensibilidad y la clasificación de la información orientan la restricción de accesos: cuanto mayores sean los efectos de una divulgación o alteración, más cuidadosa debe ser la autorización.

4.1.3. Autorización, revisión y revocación de accesos

Las altas de acceso requieren aprobación; los permisos se revisan periódicamente y se retiran cuando dejan de ser necesarios. Los cambios de función y la desvinculación de una persona disparan revisiones.

4.1.4. Integración del acceso físico y lógico

El acceso físico protege instalaciones y soportes; el lógico controla el uso de sistemas e información. Ambos deben integrarse en una misma política, evitando que un control se considere sustituto del otro.

4.2. Controles de acceso lógico

El control lógico integra identificación, autenticación, autorización, administración de permisos y monitoreo.

4.2.1. Recursos y activos sujetos a control de acceso

El control lógico abarca aplicaciones, redes, sistemas operativos, bases de datos, archivos, código fuente, utilitarios y registros. Primero se identifican recursos críticos y qué sujetos precisan utilizarlos.

4.2.2. Identificación de usuarios y procesos

Identificar consiste en reconocer de manera diferenciada a un usuario o proceso, normalmente con un identificador de cuenta. La identidad reconocida permite asociar accesos y acciones con registros de seguimiento.

4.2.3. Autenticación: conocimiento, posesión y características físicas

Autenticar significa comprobar la identidad declarada. Los factores habituales se basan en algo que el usuario sabe, posee o es; combinar factores puede mejorar la confianza respecto de una sola contraseña.

4.2.4. Autorización y asignación de permisos

La autorización determina las operaciones permitidas después de verificar la identidad. Debe basarse en tareas y necesidades de trabajo, no en otorgar acceso general por comodidad.

4.2.5. Listas de control de acceso (ACL)

Las listas de control de acceso (ACL) asocian recursos con sujetos y operaciones permitidas o denegadas. Constituyen un mecanismo para materializar permisos definidos por la política.

4.2.6. Gestión de cuentas y contraseñas

Las cuentas deben crearse formalmente, controlarse durante su vigencia y desactivarse al dejar de ser necesarias. Los secretos de autenticación deben protegerse y no deben quedar credenciales iniciales expuestas.

4.2.7. Gestión de privilegios y principio de mínimo privilegio

Los privilegios especiales permiten funciones administrativas sensibles, por lo que requieren justificación, autorización y supervisión. El mínimo privilegio significa otorgar solo los permisos necesarios para la tarea.

4.2.8. Revisión periódica de derechos de acceso

La revisión de derechos compara autorizaciones vigentes con puestos y responsabilidades actuales, y detecta permisos excesivos, obsoletos o no aprobados.

4.2.9. Supervisión y registro de accesos

La supervisión utiliza logs, registros de auditoría y otras herramientas para descubrir accesos o intentos inusuales. Debe conducir a medidas correctivas ante posibles incidentes.

4.3. Controles de acceso físico

El acceso físico añade barreras materiales y procedimientos para proteger los lugares y equipos.

4.3.1. Áreas protegidas y perímetros de seguridad

Las áreas protegidas y perímetros físicos delimitan los lugares que alojan recursos críticos. Se establecen barreras y criterios de acceso de acuerdo con la sensibilidad de las operaciones.

4.3.2. Controles administrativos de acceso físico

Los controles administrativos comprenden procedimientos de ingreso, credenciales, autorizaciones, políticas para visitantes, devolución de activos y prácticas de orden en los puestos de trabajo.

4.3.3. Controles explícitos: cerraduras, cámaras, alarmas y vigilancia

Las medidas físicas explícitas incluyen cerraduras, cámaras, alarmas, controles electrónicos y guardias. Su selección depende del tipo de recinto y del nivel de protección requerido.

4.3.4. Identificación y registro de personal y visitantes

Debe identificarse al personal y a los visitantes, autorizarse su entrada y registrarla cuando corresponda. También se controla la permanencia en áreas restringidas.

4.4. Controles ambientales

Los riesgos del entorno pueden interrumpir servicios aun sin un ataque lógico.

4.4.1. Riesgos ambientales y amenazas físicas

La seguridad del entorno considera amenazas como incendio, agua, temperatura inapropiada, fallas eléctricas y otras condiciones que comprometen personas, equipos o datos.

4.4.2. Protección de instalaciones, equipos y suministros

La protección combina condiciones del edificio, ubicación de equipos, suministros, cableado y mantenimiento. El objetivo es minimizar interrupciones y daños físicos al procesamiento de información.

4.5. Seguridad de recursos humanos

Las responsabilidades de las personas abarcan todo el vínculo laboral, antes, durante y después.

4.5.1. Selección y condiciones de contratación

La seguridad en recursos humanos comienza antes de la contratación, con revisión de antecedentes apropiada al rol y establecimiento de responsabilidades y condiciones de trabajo.

4.5.2. Capacitación, concientización y responsabilidades

Durante la relación laboral se forman y concientizan los usuarios, se comunican deberes y se refuerzan prácticas de seguridad. Las personas son parte esencial del sistema de protección.

4.5.3. Medidas disciplinarias

La organización debe prever procedimientos disciplinarios comunicados para actuar ante incumplimientos de seguridad, conforme al marco laboral y normativo aplicable.

4.5.4. Finalización o modificación de la relación laboral

Al cambiar o finalizar una relación laboral deben actualizarse obligaciones, revocarse accesos no necesarios y recuperarse activos. La continuidad de permisos antiguos genera riesgo.

4.6. Complemento obligatorio: controles organizativos de acceso ISO 27002:2022, 5.15 a 5.18

Los cuatro controles organizativos ISO 5.15 a 5.18 permiten conectar reglas de acceso con identidades, secretos y derechos.

4.6.1. 5.15 Control de acceso

ISO 5.15 exige establecer e implementar reglas de control de acceso físico y lógico fundamentadas en necesidades del negocio y seguridad. Deben contemplarse tanto sujetos como activos.

4.6.2. 5.16 Gestión de identidad

ISO 5.16 aborda el ciclo de vida de las identidades, desde su creación hasta la modificación y eliminación, garantizando que cada identidad sea apropiadamente gestionada.

4.6.3. 5.17 Información de autenticación

ISO 5.17 trata la asignación y gestión de información de autenticación, incluidas contraseñas y otros secretos, evitando su exposición y uso indebido.

4.6.4. 5.18 Derechos de acceso

ISO 5.18 contempla la provisión, modificación, revisión y revocación de los derechos de acceso, según la política y los cambios en las necesidades de las personas o servicios.

Correspondencia con el capítulo 2 (edición 2007): sección 11, control de acceso y gestión de accesos de usuarios.

5. CAPÍTULO 8 — SEGURIDAD ORGANIZACIONAL

La seguridad organizacional define responsables, estructura, activos y relaciones con terceros. Los controles de personas 6.1 a 6.8 de la norma 2022 se desarrollan en este bloque por la consigna de estudio.

5.1. Infraestructura organizacional de seguridad de la información

La estructura de gobierno de la seguridad aporta dirección, responsables y coordinación entre áreas.

5.1.1. Importancia de la infraestructura organizacional

La seguridad organizacional necesita una infraestructura de gestión que permita planificar, implantar y supervisar medidas de protección. Sin responsables definidos, los controles técnicos pierden coordinación y continuidad.

5.1.2. Estructura de gestión y dirección de la seguridad

La dirección establece políticas, prioridades y estructura para tratar la seguridad de manera coordinada. Los mecanismos deben integrarse con los procesos y objetivos de la organización.

5.1.3. Asignación y delegación de responsabilidades

Las responsabilidades deben asignarse formalmente por activos, procesos y controles. Una tarea puede delegarse, pero quien conserva la responsabilidad debe verificar su ejecución.

5.1.4. Gestor o responsable de seguridad de la información

El gestor de seguridad ayuda a elaborar y difundir políticas, seleccionar mecanismos y revisar su adecuación. Debe conocer riesgos, incidentes y necesidades de actualización; sus atribuciones dependen del tamaño y estructura organizacional.

5.1.5. Coordinación de la seguridad y comité multidisciplinario

Un equipo multidisciplinario o comité puede coordinar políticas, aprobar procedimientos, supervisar la implantación de controles y articular áreas. La seguridad no corresponde exclusivamente al sector tecnológico.

5.1.6. Difusión de políticas y procedimientos de seguridad

Las normas solo son operativas si el personal las conoce. Es necesario distribuir políticas, explicar procedimientos y fomentar la conciencia sobre amenazas y responsabilidades.

5.2. Tratamiento de activos

La gestión comienza por conocer qué activos existen y quién debe proteger cada uno.

5.2.1. Concepto y protección de activos

Un activo es cualquier elemento de valor para la organización y que, por ello, requiere protección proporcional. El material incluye activos de información, físicos, humanos, servicios y reputación institucional.

5.2.2. Tipos de activos de información y de soporte

Entre los activos primarios figuran información y procesos de negocio; como apoyo pueden identificarse hardware, software, redes, personal, infraestructura y documentación.

5.2.3. Inventario de activos

El inventario registra recursos, tipo, ubicación, propietario y criticidad, además de otras características necesarias para administrarlos. Facilita controlar protección, cambios y recuperación ante incidentes.

5.2.4. Propiedad y responsabilidades sobre los activos

Cada activo necesita un responsable que determine uso permitido y medidas de seguridad. La titularidad del activo no implica necesariamente propiedad jurídica: designa responsabilidad de gestión.

5.3. Seguridad en las relaciones con terceros

La seguridad también se gestiona cuando datos y servicios dependen de terceros.

5.3.1. Terceros, contratistas y proveedores

Las partes externas incluyen contratistas, proveedores, prestadores temporales y otras organizaciones que interactúan con información o sistemas. Deben identificarse los accesos y servicios que requieren.

5.3.2. Riesgos asociados al acceso de terceros

El acceso de terceros puede introducir riesgos de confidencialidad, integridad, disponibilidad y dependencia operativa. La organización debe analizarlos antes de habilitar servicios o compartir activos.

5.3.3. Requisitos y acuerdos de seguridad con terceros

Los acuerdos con terceros deben describir requisitos de seguridad, niveles esperados de prestación, controles, notificación de incidentes y condiciones para el manejo de información.

5.3.4. Responsabilidades y obligaciones contractuales

Los contratos aclaran obligaciones, límites de acceso, protección de información y responsabilidades ante incumplimientos. La organización no debe dar por supuesta la seguridad de un proveedor.

5.3.5. Gestión y seguimiento de servicios de terceros

La supervisión verifica el cumplimiento de compromisos, el desempeño y los cambios en servicios externos. Deben revaluarse riesgos si se modifican sistemas, proveedores o condiciones de prestación.

5.4. Complemento obligatorio: controles de personas ISO 27002:2022, 6.1 a 6.8

Los controles de personas de ISO 27002:2022 abarcan contratación, concientización, obligaciones, teletrabajo y reportes.

5.4.1. 6.1 Comprobación

ISO 6.1 recomienda la comprobación apropiada de antecedentes de candidatos antes de su incorporación y, cuando corresponda, en cambios de función, teniendo en cuenta legislación, riesgos y exigencias del puesto.

5.4.2. 6.2 Términos y condiciones de contratación

ISO 6.2 incorpora responsabilidades de seguridad de la información en los términos y condiciones de contratación, para que empleados y terceros conozcan sus obligaciones.

5.4.3. 6.3 Concienciación, educación y formación en seguridad de la información

ISO 6.3 pide concienciación, educación y formación periódica, adecuada al cargo, sobre políticas, amenazas y comportamiento esperado de las personas.

5.4.4. 6.4 Proceso disciplinario

ISO 6.4 dispone un proceso disciplinario formal y comunicado ante infracciones de políticas de seguridad, respetando requisitos legales y reglas de la organización.

5.4.5. 6.5 Responsabilidades ante la finalización o cambio

ISO 6.5 exige definir y comunicar obligaciones que subsisten o cambian al finalizar la relación laboral o modificarse el puesto, además de coordinar la protección de activos y accesos.

5.4.6. 6.6 Acuerdos de confidencialidad o no divulgación

ISO 6.6 contempla acuerdos de confidencialidad o no divulgación cuando sean necesarios para proteger información sensible, precisando deberes de las partes y su alcance.

5.4.7. 6.7 Teletrabajo

ISO 6.7 aborda medidas de protección para el teletrabajo: acceso remoto, equipos, entorno doméstico o externo, transmisión y manejo de información fuera de instalaciones.

5.4.8. 6.8 Notificación de eventos de seguridad de la información

ISO 6.8 establece mecanismos para que el personal informe sin demora eventos observados o sospechados de seguridad de la información, permitiendo una respuesta temprana.

Correspondencia con el capítulo 2 (edición 2007): sección 8, seguridad de los recursos humanos; y sección 13, gestión de incidentes.

6. CAPÍTULO 9 — GESTIÓN DE LA CONTINUIDAD DEL NEGOCIO

La continuidad trata la capacidad de seguir operando o recuperarse ante interrupciones. Incluye análisis de riesgos, impacto de negocio, tiempos objetivo, respuesta a incidentes, alternativas de recuperación y pruebas de contingencia.

6.1. Fundamentos de continuidad del negocio

La organización debe identificar actividades críticas y sus dependencias antes de escoger tecnologías de recuperación.

6.1.1. Concepto y objetivos de continuidad del negocio

La continuidad del negocio busca mantener o restaurar actividades esenciales cuando ocurren interrupciones. El objetivo no es garantizar ausencia total de fallas, sino reducir el daño y recuperar servicios a niveles y tiempos aceptables.

6.1.2. Procesos críticos y dependencias tecnológicas

Los procesos críticos son los que resultan indispensables para sostener productos, servicios y compromisos. Pueden depender de personas, información, aplicaciones, instalaciones, redes y proveedores que también deben identificarse.

6.1.3. Continuidad, contingencia y recuperación ante desastres

La continuidad es el marco general para sostener actividades; la contingencia reúne acciones ante escenarios adversos y la recuperación ante desastres se centra en restablecer recursos y servicios afectados. Los tres conceptos están conectados, pero no son sinónimos.

6.1.4. Responsabilidades de la dirección

La dirección es responsable de aprobar prioridades, recursos y planes. Los equipos técnicos y de seguridad contribuyen con diagnóstico, coordinación y ejecución, pero no sustituyen la responsabilidad global del negocio.

6.2. Gestión de la continuidad del negocio

El enfoque combina medidas para reducir interrupciones con procedimientos de retorno a condiciones aceptables.

6.2.1. Prevención y recuperación

La gestión combina prevención, para reducir la probabilidad o efecto de un evento, con recuperación para restaurar capacidades si la interrupción sucede. Ambas deben planificarse según el impacto esperado.

6.2.2. Seguridad de la información durante las interrupciones

Durante la emergencia deben preservarse los niveles de seguridad necesarios aunque se utilicen procedimientos alternativos. La urgencia de recuperar servicios no justifica abandonar indiscriminadamente los controles de protección.

6.2.3. Integración de la seguridad con la gestión de continuidad

El plan debe incluir clasificación de procesos críticos, dependencias, riesgos, responsables, recursos y mecanismos de seguridad. La protección de datos y sistemas es un componente de la continuidad del conjunto del negocio.

6.3. Análisis de riesgos y continuidad del negocio

Los criterios de impacto y criticidad permiten ordenar la recuperación y justificar inversiones.

6.3.1. Amenazas, vulnerabilidades e interrupciones

Se identifican sucesos capaces de interrumpir operaciones, como fallas de equipos, indisponibilidad de comunicaciones, incendios o incidentes de seguridad. Las vulnerabilidades explican por qué podrían materializarse sus efectos.

6.3.2. Probabilidad, impacto y criticidad

La evaluación combina posibilidad de ocurrencia con consecuencias sobre operaciones, información y tiempo de recuperación. La criticidad ayuda a priorizar inversiones y estrategias de continuidad.

6.4. Plan de continuidad del negocio

El plan es un documento operativo: señala activación, responsabilidades, operación temporal, recuperación y revisión.

6.4.1. Estructura del plan

El plan debe precisar responsables, quién lo activa, situaciones de emergencia, comunicaciones, operación temporal, recuperación y calendario de pruebas y mantenimiento.

6.4.2. Desarrollo e implementación

La elaboración comienza por identificar necesidades y procesos críticos, analizar riesgos e impactos y seleccionar alternativas viables. La dirección valida el plan y se preparan los equipos responsables de aplicarlo.

6.4.3. Estrategias de recuperación y respuesta

Las estrategias abarcan recursos alternativos, respaldo de información, redundancia, procedimientos de emergencia y restablecimiento ordenado de operaciones. Deben permitir los niveles mínimos de servicio requeridos.

6.4.4. Pruebas del plan

Las pruebas comprueban que procedimientos y responsables puedan actuar ante escenarios plausibles. Deben registrar duración, fallas y resultados, tanto en ejercicios parciales como integrales.

6.4.5. Mantenimiento y reevaluación

El plan debe revisarse cuando cambian procesos, sistemas, instalaciones o responsables y después de pruebas e incidentes. Un plan desactualizado puede fallar precisamente cuando se necesita.

6.5. Gestión de incidentes y eventos adversos

La respuesta temprana a eventos ayuda a contener efectos y a decidir cuándo activar procedimientos de continuidad.

6.5.1. Notificación de eventos adversos

Las personas deben conocer cómo informar situaciones adversas y a quién hacerlo. La notificación oportuna facilita evaluar alcance y movilizar responsables.

6.5.2. Procedimientos de gestión de incidentes de seguridad

La gestión de incidentes precisa detección, registro, clasificación, respuesta, comunicación y aprendizaje. La continuidad se activa cuando el incidente compromete o amenaza operaciones críticas.

6.5.3. Responsables de respuesta y escalamiento

Se designan equipos y autoridades para evaluar la emergencia, escalar decisiones, contener daños y coordinar la recuperación. La claridad de roles reduce demoras y acciones contradictorias.

6.6. Planes de contingencia

El apunte detalla un proceso de contingencia desde la identificación de escenarios y recursos hasta las pruebas y actualizaciones.

6.6.1. Objetivos y alcance

El plan de contingencia define acciones y recursos para reaccionar a eventos adversos y recuperar actividades afectadas. Debe basarse en las necesidades del negocio, no solamente en la infraestructura tecnológica.

6.6.2. Identificación de situaciones de desastre

Se identifican escenarios relevantes de indisponibilidad, destrucción, pérdida de personal o comunicaciones, considerando los riesgos y condiciones reales de la organización.

6.6.3. Identificación de recursos, funciones y procesos críticos

Se enumeran procesos, sistemas, datos, instalaciones, funciones y personas críticas, junto con sus interdependencias. De esta identificación depende el orden de recuperación.

6.6.4. Análisis de impacto en el negocio (BIA)

El análisis de impacto en el negocio (BIA) estima las consecuencias de interrumpir procesos en el tiempo: pérdidas operativas, económicas, legales y de servicio. Ayuda a fijar prioridades y requisitos de recuperación.

6.6.5. Definición del tiempo de recuperación (RTO)

El RTO es el tiempo objetivo dentro del que deben recuperarse niveles mínimos aceptables de servicios, sistemas o funciones tras una interrupción. No representa el tiempo que tarda una copia de respaldo en generarse.

6.6.6. Definición del punto de recuperación (RPO)

El RPO es el punto temporal al que deben recuperarse los datos luego de una interrupción; expresa cuánta antigüedad de información puede tolerarse. Por ejemplo, un RPO de dos horas supone recuperar datos hasta un punto no anterior a dos horas respecto del incidente.

Ejemplo conjunto RTO/RPO. Si un servicio debe volver a funcionar en un máximo de 4 horas (RTO = 4 h) y la organización tolera recuperar datos hasta 30 minutos antes del incidente (RPO = 30 min), necesita una solución que satisfaga ambos límites. Recuperación de servicio y antigüedad de datos son restricciones diferentes.

6.6.7. Análisis de alternativas de recuperación

Se comparan alternativas como copias, almacenamiento remoto, redundancia, instalaciones alternativas, seguros y mantenimiento preventivo. La elección debe atender a criticidad, impacto y restricciones de recursos.

6.6.8. Informe y selección de alternativas de recuperación

Las opciones se documentan con costos, beneficios, limitaciones y recursos humanos o materiales exigidos. El informe respalda las decisiones de la dirección sobre qué estrategia implantar.

6.6.9. Desarrollo del plan de contingencia y equipos de respuesta

Se constituyen equipos de coordinación, respuesta inmediata y recuperación, con procedimientos de activación y comunicación. Deben identificarse aplicaciones y recursos críticos y contemplarse daños y causas del incidente.

6.6.10. Procedimientos de restauración de servicios e información

La restauración comprende recuperar infraestructura, aplicaciones, información y operaciones de negocio en orden priorizado. Los procedimientos deben documentar requisitos, responsables y verificaciones posteriores.

6.6.11. Entrenamiento, simulacros y pruebas integrales/parciales

El apunte distingue pruebas integrales, parciales y simuladas. El personal necesita formación y ejercicios que pongan a prueba el plan y midan los tiempos y problemas encontrados.

6.6.12. Evaluación, actualización y mejora del plan

La evaluación después de los ejercicios debe incorporar hallazgos, modificaciones tecnológicas y cambios del negocio. Se actualizan procedimientos, responsables y estrategias para mantener el plan vigente.

6.7. Complemento obligatorio: controles ISO 27002:2022, 5.29 a 5.31

Estos tres controles no tienen exactamente la misma naturaleza: 5.29 y 5.30 son directamente de continuidad; 5.31 es de cumplimiento.

6.7.1. 5.29 Seguridad de la información durante la interrupción

ISO 5.29 indica que la organización planifique cómo mantener un nivel adecuado de seguridad de la información durante interrupciones, contemplando procedimientos, protección y recuperación.

6.7.2. 5.30 Preparación de las TIC para la continuidad del negocio

ISO 5.30 solicita preparar las TIC para dar soporte a la continuidad: requisitos de recuperación, soluciones de resiliencia, planes y pruebas regulares de las capacidades de respuesta tecnológica.

6.7.3. 5.31 Identificación de requisitos legales, reglamentarios y contractuales

ISO 5.31 exige identificar, documentar y mantener actualizados los requisitos legales, reglamentarios y contractuales relevantes para la seguridad de la información. Se incluye aquí por indicación del profesor, aunque su objeto es el cumplimiento y no la recuperación técnica.

Correspondencia con el capítulo 2 (edición 2007): secciones 14, continuidad de negocio, y 15, cumplimiento.

Referencias de las fuentes

- Auditoría y Control Interno, capítulo 2: Control interno y auditoría informática (20 páginas del extracto utilizado).
- Seguridad y Controles, apuntes de Seguridad en los Sistemas de Información (UTN FRRo), capítulos 6, 7, 8 y 9.
- Seguridad en los Sistemas de Información, capítulo 2: Código de buenas prácticas (estructura ISO/IEC 27002:2007).
- UNE-EN ISO/IEC 27002:2023, versión española de ISO/IEC 27002:2022; apartados 5.15–5.18, 5.29–5.31, 6.1–6.8, 7.1–7.14 y controles relacionados mencionados en el texto.

Nota: el resumen constituye una reorganización pedagógica del material para estudiar; no sustituye la lectura completa de la norma ni la normativa vigente.